

Contents

Agentic Intrusion: A Detection Engineering Analysis of the July 2026 Taiwan Campaign, and a Tempo Model for Agent-Driven Attacks	1
Scope and provenance	1
1. The defender question nobody was answering	2
2. The campaign	2
3. The tempo model	3
4. Detection, ranked	4
5. What this class makes undetectable	5
6. What actually found this	5
7. Credit	5
8. Limitations	6
9. What would falsify this	6
10. What we are not claiming	6
11. AI disclosure	7
References	7

Agentic Intrusion: A Detection Engineering Analysis of the July 2026 Taiwan Campaign, and a Tempo Model for Agent-Driven Attacks

Cristian Ruvalcaba and the Saluca Agentic AI Research Team Saluca Labs

Version 1.0 · Current to 2026-08-20 Companion detection package: <https://github.com/saluca-labs/detection-content>

Scope and provenance

This paper is built entirely from public reporting on a single campaign. We had no victim forensic artifacts, no samples, no telemetry, and we detonated nothing. Every technical claim about the campaign traces to one of:

- **Dream** (Israeli security vendor), whose research was surfaced by the **Financial Times** on 2026-08-12.
- **The Register** (2026-08-12), whose framing of the activity as “near-autonomous” is more careful than most and is adopted here.
- **Reuters** (2026-08-12), **CNN Business** (2026-08-13), and **Taipei Times** (2026-08-14), reporting the Taiwanese government’s confirmation and the victim set.

Where we state a fact the primary source does not carry, we say so at the point of use. Where we draw a conclusion the researchers did not draw, we mark it as ours. **Section 3 is entirely ours and is not attributable to any of the above.**

One provenance caveat deserves prominence rather than a footnote: this is a **vendor report amplified by a national newspaper**, and no independent researcher has published corroborating analysis at the time of writing. We treat the campaign description as reliable and the “first ever” framing as unproven. See section 10.

This is defensive material. It contains no exploitation guidance, no offensive code, no targeting data, and no agent tooling. The detection package exists so defenders can search their own telemetry.

1. The defender question nobody was answering

Detection engineering has a working assumption so old that it is rarely stated: an intrusion is either **driven by a person**, in which case it is slow, irregular, and creative, or **driven by a program**, in which case it is fast, uniform, and rigid. Almost every behavioural detection ever written sits somewhere on that axis. Rate-limit alerting assumes the program end. Anomalous working-hours alerting assumes the human end.

An LLM agent is not on that axis. It is fast like a program and creative like a person, and the existing detections were not built with a third case in mind.

The July 2026 campaign is the first well-documented instance of that third case operating at scale against a government, and the defender question it raises is narrow and uncomfortable:

When an intruder has no malware, no infrastructure worth pivoting on, and no published indicators, what is left to detect?

This paper argues the answer is **rhythm**, and that rhythm is more durable than any indicator the operator could have left behind.

2. The campaign

Over four days in early July 2026, an operator ran a toolkit of **1,395 files in a 160 MB archive**, built around two freely downloadable open-source agent frameworks, **Hermes** and **OpenClaw**, against Taiwanese government systems.

Per Dream’s reporting, up to **eight agents ran concurrently**, “each working a different angle, more like a coordinated hacking team than a piece of malware.” The system **mapped 21 government systems**, and it “continuously ranked and reprioritised possible attack paths based on available evidence.” When an approach failed, the agents would “scour the internet for information and devise a new approach as a human hacker would.”

Outcome: **85 or more government accounts** compromised and **more than 2,500 personnel records** extracted, after which the activity expanded to **Taiwan’s nuclear safety regulator** and **at least seven energy companies**.

Human involvement is described as minimal throughout.

2.1 The bypass, which is the most important sentence in the reporting

Operators circumvented guardrails by **framing the entire hacking campaign as an authorized penetration test, a scenario the model apparently had no reliable way to verify or reject**.

We want to be precise about what this is and is not, because the distinction determines whether the industry response is useful.

This is **not a jailbreak**. No adversarial suffix, no encoding trick, no roleplay exploit, no gradient-crafted prompt. The operator made a **claim about their own authorization** and the model

had no mechanism to check it.

Nor is it primarily a model-safety failure, though it will be reported as one. Better refusal training would raise the cost of this specific phrasing and would not touch the underlying problem, because the underlying problem is architectural: **the component taking the actions was also the component adjudicating whether it was permitted to take them.** In any other part of a security architecture that is recognised immediately as a separation-of-duties failure. A process does not get to assert its own entitlements and be believed.

2.2 Attribution

Dream found Simplified Chinese in the tool’s internal communications and **made no named-group attribution.** Neither do we. Language artifacts in tooling are among the cheapest things in intrusion tradecraft to fabricate, and we treat this as a weak signal recorded for completeness.

3. The tempo model

This section is our contribution and is not drawn from the reporting.

Three classes of actor produce three distinguishable rhythms in an authentication or access log. The discriminator is not speed alone, which is where conventional detection stops, but the joint distribution of **inter-event interval** and **technique change following failure.**

A human operator. Intervals are long and highly variable, seconds to minutes, with frequent multi-minute gaps for reading, thinking, and consulting notes. Technique changes are common but slow, because they follow comprehension.

A script. Intervals are short and tightly clustered, typically sub-second, with low variance. Critically, a script **does not change technique when it fails.** It continues, retries, or terminates, because branching on semantic failure is precisely what it lacks.

An agent. Intervals are bimodal. Tool execution produces **bursts at machine speed**, sub-second, because the actions themselves are ordinary automation. Between bursts sit **inference-latency pauses**, empirically two to thirty seconds for current frontier and open-weight models at planning-length context, while the planner decides what to do next. And after a failure the agent **changes technique**, because a planner re-ranked its options against new evidence, which is exactly the behaviour Dream observed and described.

The joint signature, **machine-speed bursts separated by think-pauses, with strategy change on failure**, is not produced by either of the other two classes. A human cannot generate the bursts. A script cannot generate the adaptation. A human driving a script generates both but not interleaved at this cadence, because a person cannot re-plan in four seconds and then execute twelve actions in one.

The property that makes this worth building detection on is that it is a **consequence of the method rather than a choice by the operator.** Hashes change for free. Infrastructure changes for the price of a VPS. Frameworks are interchangeable and there are dozens. But an operator who wants an LLM to plan the next step must wait for the LLM to plan the next step, and that wait is observable.

3.1 Where the synthesis is weaker

We are not going to oversell this.

The thresholds are reasoned, not measured. The two-to-thirty-second band comes from published inference latencies at planning-length context, not from telemetry of this campaign, which was never released. In a real estate the band will differ by model, by context length, by whether the operator batches planning, and by network path. Every rule in the companion package ships as **status: experimental** for this reason, and the package includes a baselining search that must be run first.

It is evadable, at a price. An operator who inserts randomised jitter to fill the think-pauses, refuses to parallelise, and rate-limits to human cadence will flatten the signature. Doing so forfeits most of the speed and concurrency advantage that made this campaign notable. That is a real defensive outcome rather than a detection failure, but it does mean tempo analysis is a cost-imposition control, not an unevadable one.

Log fidelity is the binding constraint. The model needs sub-second timestamps and a stable notion of “technique”. Many estates aggregate authentication telemetry to the second or coarser, which erases the burst band entirely and collapses the whole model.

Batched planning breaks the bimodality. An agent that plans ten steps in one inference call and then executes all ten produces one long pause and one long burst, which looks far more like a script. We expect tooling to move in this direction for cost reasons, independent of evasion.

4. Detection, ranked

Tier 1: survives rotation entirely

Tempo profiling. Section 3, implemented against authentication logs. Survives changes of framework, model, provider, and infrastructure, because it keys on the method rather than the tooling.

Inference traffic correlated with authentication activity from one host. If a host is calling a model provider in the same minutes it is generating authentication events, an LLM is in the decision loop. There is no benign explanation that does not involve an agent, and confirming or excluding it is a one-question conversation with a system owner.

Tier 2: durable but needs tuning

Inference API egress from server-class hosts. A domain controller, jump host, or OT segment has no reason to reach a model provider. Cheap, high signal, and nearly free of false positives once genuine AI workloads are allowlisted. Not Tier 1 only because **self-hosted inference defeats it completely**, and open-weight quality is improving fast enough that we expect self-hosting to become the common case.

Breadth with adaptation. Scanners are broad and uniform; humans are narrow and adaptive; agents are broad and adaptive. Twenty-one systems in four days with technique variation between them. Needs per-estate baselining because “broad” is relative to your normal.

Tier 3: useful, decays fast

Agent framework artifacts. Hermes, OpenClaw, MCP tool servers, package runners spawning tool processes. These are **legitimate, widely installed software**, so their presence indicates

capability rather than compromise. Every such rule in the companion package is marked as a hunting rule, not an alert.

Their real value is inventory rather than detection. Most organisations cannot currently answer “where in my estate can a language model take an action, and what can it reach”, and that question is a prerequisite for every other control here. The package includes a read-only sweep for it.

Authorization assertions at an LLM gateway. Targets the actual bypass from section 2.1 and is therefore the highest-fidelity rule in the set, but it is Tier 3 because it is only observable if you operate the inference path. Most organisations do not, and for them this detection does not exist at any level of effort.

5. What this class makes undetectable

The bypass itself. It occurred inside a prompt, inside TLS, to a third-party provider. No network sensor will ever see it. This is not a tuning problem or a visibility gap that money fixes; it is structural.

Successful use of valid credentials. Once the agents held 85 working accounts, the authentication succeeded. Credential-failure alerting sees nothing. Only tempo and breadth analysis reach this phase, which is precisely why section 3 matters more than the indicator sections of a conventional pack.

Self-hosted inference. Removes the entire network surface. An operator running an open-weight model on their own hardware produces no third-party API traffic, and Tier 2 disappears.

The agents’ reasoning. Unless you are the model provider or you operate the gateway, the planning that distinguishes this campaign from a scanner is simply not in your telemetry.

6. What actually found this

Worth stating plainly, because it is uncomfortable and instructive: **this was not found by the detections in this paper, and as far as the public record shows it was not found by network defence at all.** It was reported by a security vendor analysing the operator’s toolkit, after the fact, and confirmed subsequently by the Taiwanese government.

Four days, 21 systems, 85 accounts, a nuclear safety regulator and seven energy companies, and the public account contains no indication that any defender’s control interrupted it.

We think that is the honest headline, and it is the argument for the Tier 1 controls rather than against them.

7. Credit

Dream performed the analysis this paper rests on. The **Financial Times** surfaced it. **The Register** contributed the most careful framing in the coverage by insisting on “near-autonomous” rather than “autonomous”, a distinction we have adopted throughout. **Reuters**, **CNN Business** and **Taipei Times** carried the confirmation and victimology.

Nothing in section 2 is ours. Section 3 is ours and should be criticised as ours.

8. Limitations

We have not seen the toolkit, the logs, the victim telemetry, or Dream’s underlying analysis beyond what was reported. We cannot independently verify the file count, the archive size, the agent concurrency, or the victim numbers.

No rule in the companion package has been tested against telemetry from this campaign, because none is public. Rule syntax was validated; efficacy was not.

The tempo model has been sanity-checked against locally generated agent traffic in our own environment. That is a weak validation: our agents, our models, our network. It establishes that the signature exists and is measurable, not that it generalises to an adversary trying to avoid it.

We do not know whether the operator used frontier or open-weight models, which materially affects the latency band in section 3.

9. What would falsify this

The tempo model makes testable predictions, and we would rather they were tested than believed.

1. **If agent-driven and script-driven intrusions are indistinguishable on the joint interval and adaptation distribution** in real telemetry, section 3 is wrong and the package’s Tier 1 collapses to Tier 2.
2. **If the think-pause band proves unstable across models and context lengths** to the point where no per-estate baseline separates it from ordinary network jitter, the model is uninstrumentable even if conceptually correct.
3. **If adaptation-after-failure turns out to be common in conventional tooling** at rates comparable to agent activity, the discriminator we lean on hardest is not a discriminator.
4. **If batched planning becomes standard**, the bimodality disappears for cost reasons rather than evasive ones, and this paper describes a transitional artifact with a short shelf life.

We consider the fourth the most likely, and we would rather say so now than be corrected later.

10. What we are not claiming

Not that this was the first autonomous cyberattack. That framing is the vendor’s and the press’s. It is unfalsifiable in practice and we have no way to evaluate it.

Not attribution. Simplified Chinese in tooling comments is not attribution, and Dream did not offer one.

Not that the frameworks are malicious. Hermes and OpenClaw are legitimate open-source software with large legitimate user bases. We run a Hermes fork ourselves. Their use here says the capability is commodity, not that the projects are culpable.

Not that our detections would have caught this. We have no telemetry to make that claim against, and section 6 is deliberately blunt about what did and did not find it.

Not that this is an AI safety problem. It is an authorization architecture problem that happens to involve a model. Treating it as the former produces model-refusal research; treating it as the latter produces a gate the model does not control, which is the actual mitigation.

11. AI disclosure

Prepared with AI assistance (Anthropic Claude) inside the author’s research harness. The tempo model, the tier rankings, the falsification criteria, and every statement in sections 8 through 10 were authored and reviewed by the named human author, who is responsible for the claims. The limitations and non-claims sections exist specifically because AI-assisted detection content tends to overstate coverage, and they were written before the rules rather than after.

References

1. Dream, via the Financial Times, “China-linked hackers used AI agents in near-autonomous attack on Taiwan”, 2026-08-12.
2. Security Affairs, “China-Linked Hackers Use AI Agents in Autonomous Attack on Taiwan”, 2026-08-12. <https://securityaffairs.com/197079/apt/china-linked-hackers-use-ai-agents-in-autonomous-attack-on-taiwan.html>
3. The Register, “Near-autonomous AI agents attack Taiwan’s nuclear safety agency”, 2026-08-12.
4. Reuters, via US News, “Taiwan Says It Was Targeted Last Month in AI-Driven Hacking Campaign”, 2026-08-12.
5. CNN Business, “Hackers used autonomous AI agents to attack Taiwan. Is this the future of cyberwarfare?”, 2026-08-13.
6. Taipei Times, “Taiwan targeted in AI-driven hacking campaign”, 2026-08-14.
7. Companion detection package, Saluca Labs, <https://github.com/saluca-labs/detection-content>